
OrdenExchange

Documento de diseño

La casa de cambio P2P del ecosistema: cómo está construida, cómo funciona una compraventa con custodia, cómo se verifica la identidad contra Genesis ID, qué protege el dinero de la gente, y qué falta para ir a producción.

Express + TypeScript

23 países · 19 monedas

Custodia con aritmética exacta

KYC real contra Genesis ID

Cadena 5550 · ORIGEN · AUKA · AGKA

75 pruebas de extremo a extremo

Versión 1.0 · 20 de septiembre de 2026

Rama `claude/p2p-marketplace-latam-9rfd9g` del monorepo `express-js-on-vercel`, carpeta `ordenexchange/`

Escrito sobre el código tal como está: cada afirmación corresponde a algo que se puede leer en el repositorio o reproducir con las pruebas.

Índice

1 Resumen ejecutivo

2 Dónde encaja en el ecosistema

3 Arquitectura técnica

4 Modelo de datos

5 Cómo funciona una compraventa

6 Custodia: las tres reglas

7 Precio de referencia

8 Países, monedas y métodos de pago

9 Identidad: KYC contra Genesis ID

10 Agentes de cambio

11 Billetera, depósitos y retiros

12 Las pantallas de la app

13 Panel de operadores

14 Seguridad

15 La API, en resumen

16 Despliegue y configuración

17 Pruebas

18 Lo que falta y lo que sigue

19 Glosario

1 · Resumen ejecutivo

OrdenExchange es un mercado entre personas (P2P) para comprar y vender **ORIGEN** —y también AUKA y AGKA— a cambio de la moneda de cada país de Latinoamérica, pagando por transferencia bancaria o por las billeteras que cada país usa de verdad: PIX, Nequi, Yape, SINPE Móvil, Tigo Money, Pago Móvil, Mercado Pago, SPEI, Zelle... Funciona como Binance P2P: alguien publica un anuncio, otra persona lo toma, la plataforma **custodia el activo** mientras el dinero viaja por fuera, y lo libera cuando el vendedor confirma que cobró. Si algo falla, un operador resuelve la apelación leyendo el chat y los comprobantes.

Para operar hace falta una identidad verificada en **Genesis ID**, la identidad del ecosistema Orden Global. OrdenExchange no verifica a nadie por su cuenta: acompaña a la persona en el trámite (datos, documento, rostro) y una persona del equipo de cumplimiento aprueba en Genesis ID. Cada compraventa completada se reporta al monitoreo de lavado de activos de ambas partes.

23

países de Latinoamérica con su moneda, sus bancos y sus métodos de pago reales

3

activos anclados al metal: ORIGEN (1/55 g de oro), AUKA (1 oz de oro), AGKA (1 oz de plata)

75

pruebas automáticas sobre el servidor real: 47 en demostración y 28 contra un Genesis ID de verdad

0

llaves privadas en el servidor: los depósitos se comprueban en la cadena y los retiros los firma un operador

3

reglas de custodia que ninguna operación puede romper (y una prueba que las verifica sobre todos los saldos)

2

idiomas en toda la app y el panel (español e inglés), con formato de moneda por país

Qué está hecho y funciona hoy

- **Mercado** con anuncios de compra y venta por país, moneda, activo y método de pago; precio fijo o flotante sobre la referencia del metal; filtros y orden como en Binance P2P.
- **Órdenes** con custodia, temporizador de pago (15 a 60 minutos), chat con imágenes (comprobantes), marcar pagado, liberar con contraseña, cancelación, vencimiento automático, apelaciones y calificaciones.
- **Billetera** con saldo disponible y en custodia por activo, depósitos comprobados en la cadena 5550 por hash, retiros que firma un operador, historial de movimientos.
- **Agentes de cambio**: comerciantes verificados con garantía en ORIGEN, insignia y límites mayores; solicitud, aprobación, suspensión y renuncia.
- **Identidad**: registro con confirmación del correo, asistente de verificación en tres pasos contra Genesis ID, sesión única del ecosistema, tamizado de direcciones, monitoreo AML.
- **Panel de operadores** con roles (admin, soporte, auditor): apelaciones, órdenes, usuarios, retiros, depósitos, agentes, precios, configuración, bitácora encadenada.
- **Modo demostración** con diez usuarios verificados en nueve países, saldos y anuncios, que nunca se enciende en producción.
- **Interfaz** en español e inglés, pensada primero para el teléfono, con movimiento gastado en una sola idea: la custodia (sección 12).

Qué falta para producción

Lo que falta no es código de OrdenExchange sino **infraestructura y decisiones**: una base MongoDB (el archivo JSON sirve para desarrollo, no para custodiar saldos), la clave real de la app en Genesis ID, el proveedor de correo

(Brevo) para los códigos de confirmación, la cuenta tesorería en la cadena 5550 y quién la firma, un proveedor de biometría en Genesis ID (sin él, cada rostro lo coteja una persona), y el precio del metal alimentado desde una fuente automática. Se detallan en la sección 19.

2 · Dónde encaja en el ecosistema

OrdenExchange es una pieza más de Orden Global y se apoya en las que ya existen en lugar de repetirlas. No custodia dinero de curso legal: los pagos entre personas van por fuera, por los bancos y billeteras de cada país. Sí custodia el activo digital mientras dura una orden.

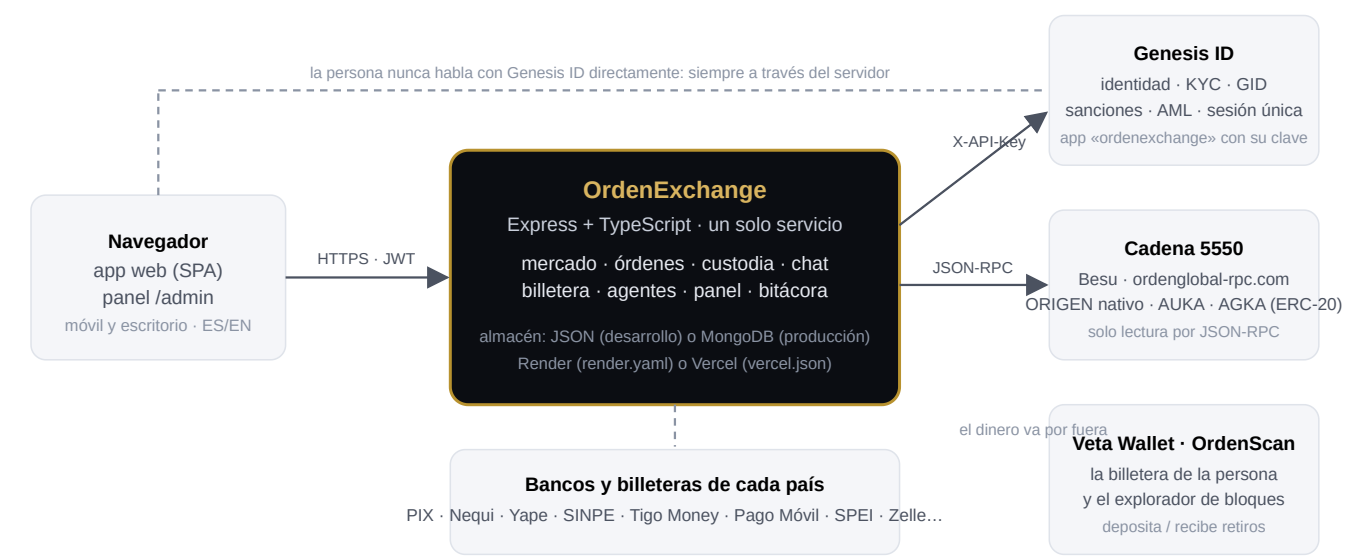


Figura 1 · OrdenExchange y las piezas del ecosistema con las que habla. Ninguna clave ni llave privada sale del servidor.

PIEZA	QUÉ LE DA A ORDENEXCHANGE	CÓMO
Genesis ID	Quién es cada persona (GID), si puede operar, tamizado de sanciones, monitoreo AML, sesión única entre apps.	App ordenexchange registrada en genesis-id/src/auth/aplicaciones.ts con alcances: identidad.crear/leer/documento, gid.verificar/perfil, vinculo.crear, movimiento.enviar, tamiz.direccion, telemetria.enviar, directorio.enviar.
Cadena 5550	Los activos. Depósitos comprobados por hash de transacción; retiros que un operador firma desde la tesorería.	JSON-RPC de solo lectura (eth_getTransactionByHash , recibos, evento Transfer para AUKA/AGKA). Sin llaves privadas.
Veta Wallet	La billetera desde la que la persona deposita y a la que retira (su dirección 0x en el perfil).	La persona pega el hash del depósito; el servidor lo verifica.
ULTRON	El cerebro del ecosistema conoce OrdenExchange (base de conocimiento) para responder sobre él.	ULTRON-APP/src/05-cerebro-og/conocimiento.ts .
Render / Vercel	Despliegue.	Servicio ordenexchange en render.yaml (raíz del monorepo) y vercel.json propio.

3 · Arquitectura técnica

Un solo servicio Node (Express + TypeScript, ESM, ejecutado con `tsx`) sirve la API, la app web y el panel. La lógica vive en el **motor**; las rutas son finas: validan la sesión y llaman al motor. El estado entero está en un documento (archivo JSON en desarrollo, documento de MongoDB en producción), con dos colecciones aparte para lo que pesa: las imágenes del chat y, en Mongo, nada más. Es el mismo patrón de almacén que Genesis ID.

CARPETA / ARCHIVO	QUÉ HAY
<code>src/index.ts</code>	Arranque: CSP y HSTS, CORS, <code>trust proxy</code> condicional, parsers, rutas, app y panel estáticos, <code>/healthz</code> , tareas periódicas (órdenes vencidas cada 30 s, cola AML cada 30 s).
<code>src/types.ts</code>	El modelo de datos entero, comentado (sección 4).
<code>src/motor/</code>	<code>billetera</code> (custodia), <code>ordenes</code> , <code>anuncios</code> , <code>usuarios</code> , <code>agentes</code> , <code>metodosPago</code> , <code>precios</code> , <code>genesis</code> (cliente), <code>aml</code> (cola de reportes), <code>cadena</code> (JSON-RPC), <code>correo</code> (Brevo), <code>imagenes</code> , <code>operadores</code> , <code>bitacora</code> , <code>demo</code> .
<code>src/routes/</code>	<code>auth</code> , <code>genesis</code> , <code>mercado</code> , <code>anuncios</code> , <code>ordenes</code> , <code>billetera</code> , <code>metodosPago</code> , <code>agentes</code> , <code>panel</code> .
<code>src/lib/</code>	<code>decimal</code> (BigInt a 18 decimales), <code>cripto</code> (bcrypt, JWT, HMAC), <code>sesion</code> (guardias), <code>limite</code> (peticiones por minuto), <code>errores</code> (Falla con código), <code>entorno</code> (una sola definición de «producción»), <code>uid</code> .
<code>src/data/</code>	<code>latam.ts</code> (23 países: moneda, bancos, métodos de pago con sus campos canónicos), <code>activos.ts</code> , <code>monedas.ts</code> , <code>fxSemilla.ts</code> (tasas iniciales USD → moneda local).
<code>public/</code>	La app (<code>index.html</code> , <code>app.js</code> , <code>app.css</code> , <code>i18n.js</code>) y el panel (<code>admin.html</code> , <code>admin.js</code> , <code>admin.css</code>). Vanilla, sin framework ni compilación; enrutado por <code>#/ruta</code> .
<code>src/pruebas/</code>	<code>decimal.test.ts</code> , <code>flujo.test.ts</code> (demostración), <code>genesis.integracion.ts</code> (contra Genesis ID real).
<code>README.md</code> · <code>API.md</code> · <code>DISEÑO.md</code>	Cómo se arranca, el contrato HTTP completo, la guía del frontend.

Decisiones que conviene conocer

- **Un único punto muta los saldos.** Todo cambio de saldo pasa por `billetera.mover()`, que aplica el movimiento entero o lo rechaza entero, y deja un registro con su referencia. No hay otra vía.
- **Aritmética exacta.** Cantidades y precios son cadenas decimales; se opera con BigInt a 18 decimales (`lib/decimal.ts`) y los recortes van siempre hacia abajo. No hay coma flotante en dinero.
- **«Producción» tiene una sola definición** (`lib/entorno.ts`): `NODE_ENV=production`, Render, Vercel, Mongo configurado o tesorería configurada. Con cualquiera de esas señales, el modo demostración no se enciende aunque se pida, el secreto de sesiones es obligatorio y las cuentas de demostración se congelan.
- **La clave de Genesis ID vive solo en el servidor.** El navegador habla con `/api/genesis/*` y el servidor reenvía con `X-API-Key`, igual que el puente de Veta Wallet y MyTokenPay.
- **Sin marco de frontend.** La app es HTML/CSS/JS plano con estado en memoria y `localStorage` solo para la sesión y el país. Sondeo cada pocos segundos dentro de una orden; no hay WebSockets.
- **Todo en español, con inglés completo.** Código, comentarios, rutas y textos en español; la interfaz cambia a inglés con un clic (`i18n.js`).

4 · Modelo de datos

Todo está en `src/types.ts`. Las cantidades son cadenas decimales; las fechas, ISO 8601. Los identificadores llevan prefijo (`usr_`, `ord_`, `anu_`...). Lo que sale por la API es una **vista**: nunca el correo ni el nombre legal entero de otra persona, nunca los datos bancarios fuera de una orden abierta.

ENTIDAD	CAMPOS CLAVE	NOTAS
Usuario	email, emailVerificado, hashContrasena, apodo, pais, idioma, telefono, direccionCadena, gid, gidEstado, nombreLegal, agente, congelado, reputacion, sesionesDesde	<code>gidEstado</code> : sin-verificar · en-revision · verificada · rechazada · suspendida. <code>sesionesDesde</code> revoca todos los JWT anteriores a ese instante.
Saldo	usuariold, activo, disponible, congelado	Dos bolsillos por activo. Ninguno baja de cero.
Movimiento	tipo, activo, disponible ($\pm$), congelado ($\pm$), referencia, descripción, fecha	Tipos: deposito, retiro-solicitado/enviado/rechazado, orden-congelar/descongelar/liberar/recibir, comision, garantia-agente, garantia-devuelta, ajuste, faucet. La suma de movimientos ES el saldo.
Anuncio	lado, activo, moneda, pais, tipoPrecio (fijo/flotante), precio o margen, cantidadTotal/Disponible, limiteMin/Max, metodos, ventanaPagoMin (15–60), terminos, respuestaAutomatica, requisitos, estado	Estados: activo · pausado · agotado · cerrado. Requisitos para la contraparte: GID verificado, órdenes mínimas, tasa de finalización, días registrado, solo agentes.
Orden	numero, anunciold, compradorId, vendedorId, activo, moneda, precio, cantidadActivo, montoFiat, comision, metodoPago (copia), estado, venceEn, referenciaPago, apelacion, apelacionesPrevias, calificaciones, mensajes, imagenesChat	Estados: pendiente-pago · pagado · apelacion · completada · cancelada. Guarda una copia del método de pago tal como estaba al abrirse.
Mensaje	de (comprador/vendedor/sistema/operador), texto, imagen (id), fecha, vistoPor	Máximo 300 mensajes y 6 imágenes por orden; el chat cierra 24 h después de terminar. Las imágenes viven aparte y se sirven con URL firmada.
MetodoPago	pais, tipo, banco, titular, campos (canónicos por método), activo	Validado contra el catálogo del país. No se desactiva si está en un anuncio abierto.
SolicitudAgente	usuariold, estado, garantia, decididaPor, motivo	La garantía se congela al solicitar y se devuelve al renunciar o rechazar.
Deposito · Retiro	activo, cantidad, direccion, txHash, estado, decididoPor	Retiro: pendiente · enviado · rechazado · cancelado. El hash de retiro es único.
Operador · SesionOperador	email, rol (admin/soporte/auditor), hashContrasena; sesión guardada por hash del token	Bloqueo por correo+IP tras intentos fallidos.
Precios · Configuracion	oroUsdOnza, plataUsdOnza, fx{}, fuente; comisionPct, garantiaAgente, maxOrdenesAbiertas, minOrdenUsd, maxOrdenUsdSinAgente, confirmacionesDeposito, tesoreria	Editables desde el panel; al arrancar salen del entorno y de la semilla.
EntradaBitacora	actor, accion, objeto, detalle, hashAnterior, hash	Cadena de hashes: el panel comprueba que está íntegra.
ReporteAml	gid, movimiento, intentos, ultimoIntento, ultimoError	Cola persistente hacia el monitoreo de Genesis ID (sección 11).

Vistas públicas

`UsuarioPublico` (lo que ve cualquiera en el mercado): apodo, país, insignias (verificado, agente), reputación, nombre abreviado («Juan P.», derivado del nombre legal), en línea. `UsuarioPropio` (solo el dueño): además correo, GID, estado de verificación, nombre legal, dirección de la cadena, `puedeOperar` y `motivoNoOpera`. La orden se devuelve con `acciones` (qué botones tienen sentido para quien la mira) para que el frontend no tenga que reconstruir las reglas.

5 · Cómo funciona una compraventa

El modelo es el de Binance P2P: la plataforma no compra ni vende, **pone en contacto** a dos personas, custodia el activo mientras el dinero viaja por fuera y arbitra si hace falta. Quien vende ORIGEN lo deja congelado en cuanto nace la orden; quien compra paga en su moneda por el método pactado y lo dice; el vendedor comprueba que cobró y libera.

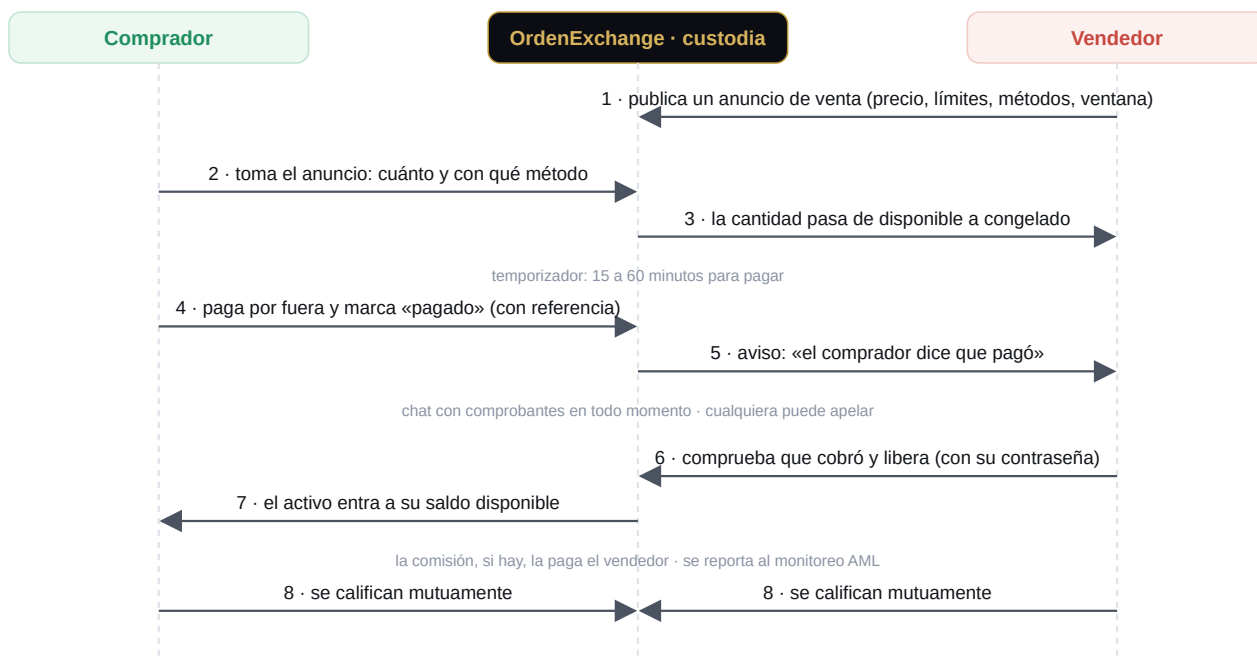


Figura 2 · Una orden sobre un anuncio de venta. Sobre un anuncio de compra es igual, con los papeles cambiados: quien toma el anuncio es el vendedor y deja el activo en custodia.

Las reglas, una por una

- 1 Publicar un anuncio.** Lado (compro / vendo), activo, moneda del país, precio fijo o flotante (un porcentaje sobre la referencia, p. ej. 103 %), cantidad total, límites por orden, hasta varios métodos de pago propios, ventana de pago (15, 30, 45 o 60 min), términos, respuesta automática y requisitos para la contraparte (GID verificado, mínimo de órdenes, tasa de finalización, antigüedad, solo agentes). Un anuncio de venta solo aparece en el mercado si el vendedor tiene saldo para la orden mínima; un precio fijo diez veces fuera de la referencia se rechaza (casi siempre es un cero de más).
- 2 Tomar un anuncio.** Se elige el monto en moneda local o la cantidad de activo, dentro de los límites del anuncio, del mínimo de la plataforma (5 USD equivalentes) y del máximo para quien no es agente (5 000 USD). Máximo cinco órdenes abiertas por persona. Nadie toma su propio anuncio. Al nacer la orden, **la cantidad del vendedor pasa a custodia**; si no la tiene, la orden no nace y el anuncio se pausa.
- 3 Pagar y marcar pagado.** Los datos bancarios del vendedor se ven solo dentro de la orden. El comprador transfiere y marca «pagado», con la referencia si la tiene, antes de que venza el temporizador. Si vence sin marcarse, la orden se cancela sola y el activo vuelve al vendedor.
- 4 Liberar.** Solo el vendedor, y con su contraseña: el activo pasa entero al comprador. La comisión (por defecto 0 %) la paga el vendedor de su saldo disponible; si no le alcanza, se descuenta de lo liberado. Se recalcula la reputación de ambos y se reporta al monitoreo AML.
- 5 Cancelar.** Solo el comprador y solo mientras está pendiente de pago. Una orden marcada como pagada ya no se cancela: se apela. Un operador puede cancelar cualquier orden pendiente o pagada desde el panel, con motivo.

- 6 **Apelar.** Cualquiera de los dos, sobre una orden pagada (o pendiente, si el comprador ya pagó; o vencida hace menos de 24 h, si sí pagó: entonces la cantidad se vuelve a congelar). Una apelación por parte: quien la retira no puede abrir otra. Motivos cerrados (no recibí el pago, pagué y no liberan, monto distinto, contraparte no responde, otro). Mientras hay apelación la orden queda congelada; el vendedor puede zanjarla liberando. Un operador la resuelve: **liberar** al comprador o **devolver** al vendedor. Queda en la bitácora y cuenta como apelación perdida para quien la pierde.
- 7 **Calificar.** Positiva o negativa con comentario, una vez completada. La reputación se recalcula siempre desde las órdenes: total, completadas, tasa de finalización a 30 días (las cancelaciones del sistema no cuentan en contra), tiempos promedio de pago y de liberación, apelaciones perdidas.
- 8 **Chat.** Texto e imágenes (comprobantes comprimidos en el teléfono), hasta 300 mensajes y 6 imágenes por orden; mensajes del sistema en cada cambio de estado; el operador puede escribir en una apelación. Cierra 24 horas después de terminar la orden. Las imágenes se sirven con una URL firmada, así que solo las ven las partes y el operador.

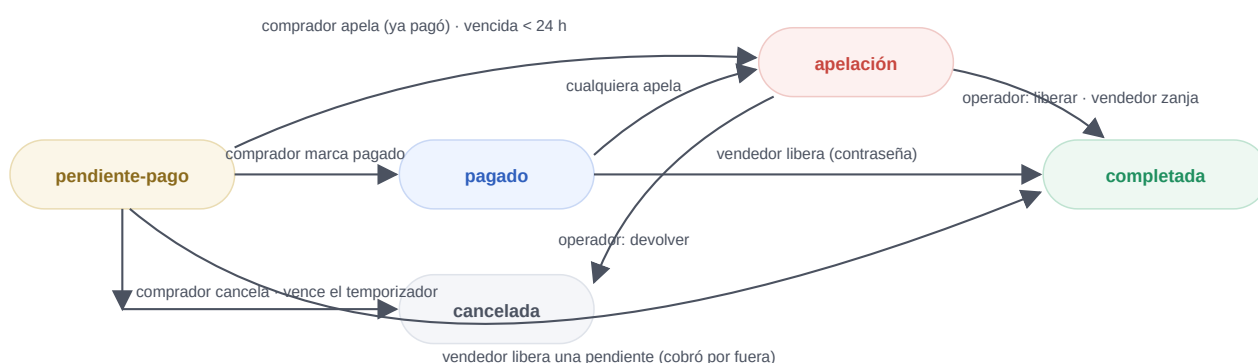
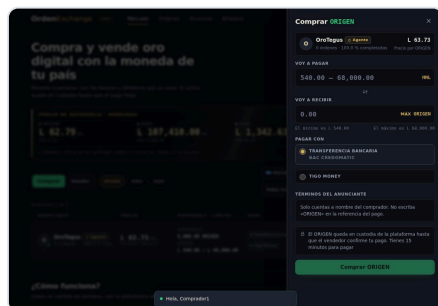
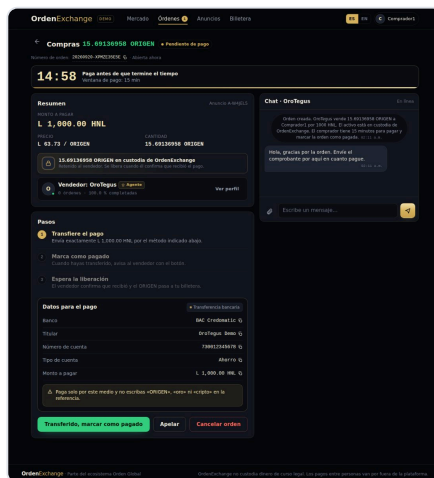


Figura 3 · Estados de una orden. Al cancelarse, el activo vuelve al vendedor; al completarse, pasa al comprador. No hay más estados ni más transiciones que estas.

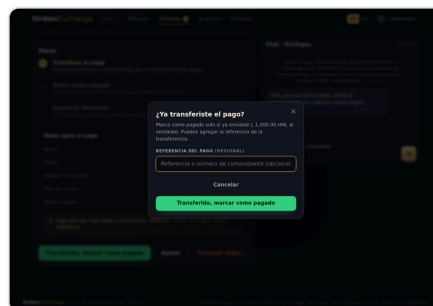
Así se ve



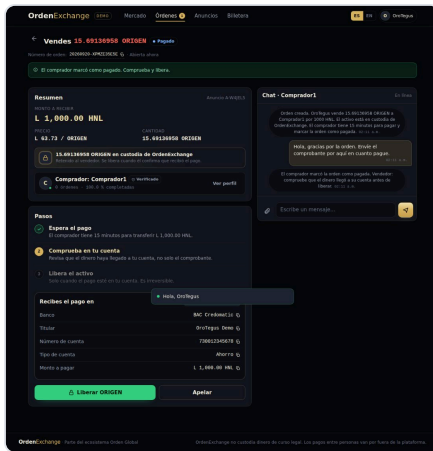
Tomar un anuncio: monto, método y resumen



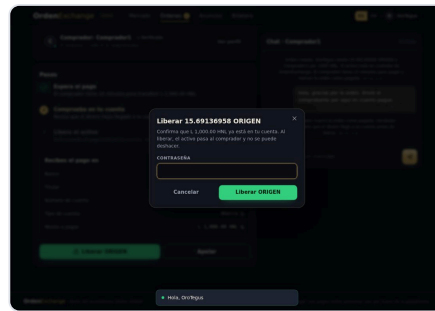
La orden del comprador: temporizador, datos de pago, chat



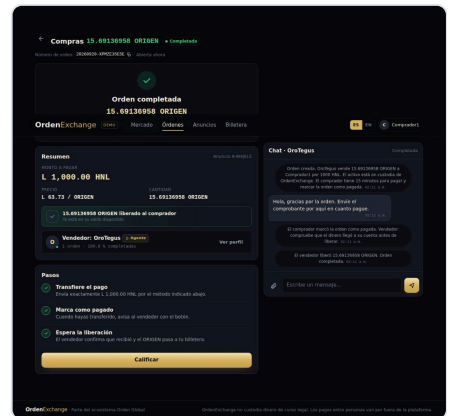
Confirmar «ya pagué» con referencia



La misma orden vista por el vendedor



Liberar exige la contraseña



Completada: calificar a la contraparte

6 · Custodia: las tres reglas

Cada persona tiene por activo dos bolsillos: **disponible** y **congelado** (custodia). Todo lo que pasa con el dinero se reduce a mover entre esos bolsillos, y hay tres reglas que ninguna operación puede romper:

1 · Ningún bolsillo baja de cero.

Un movimiento que lo haría se rechaza entero. No hay «saldo negativo temporal» ni descubiertos.

2 · Todo cambio deja un movimiento con su referencia.

La suma de los movimientos ES el saldo. La prueba de extremo a extremo lo comprueba, al final, para todos los usuarios y activos.

3 · El activo no se inventa.

Entra por un depósito comprobado en la cadena (o por el grifo de demostración, que se ve como tal) y sale por un retiro que firma un operador. Liberar una orden solo mueve custodia del vendedor al comprador; la comisión va a la tesorería.

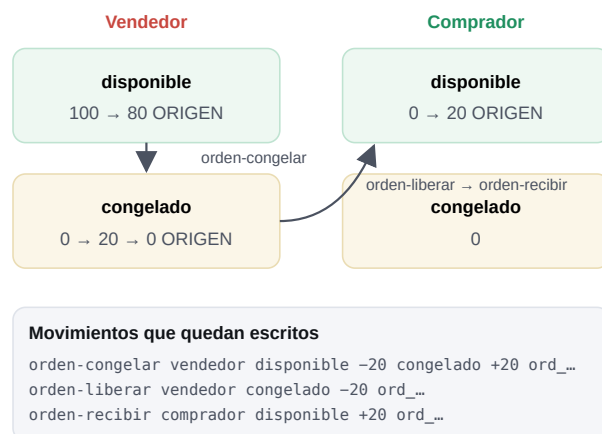


Figura 4 · Una orden de 20 ORIGEN, del anuncio a la liberación. Si se cancela, el único movimiento es «orden-descongelar».

Cómo se garantiza en el código

- `billetera.mover(usuarioId, activo, {disponible, congelado}, tipo, referencia, descripcion)` es la **única** función que toca un saldo. Calcula el resultado con `BigInt`, rechaza si algún bolsillo quedaría negativo, escribe el saldo y el movimiento en la misma operación y guarda.
- Las operaciones de negocio se componen de esas llamadas: `congelar`, `descongelar`, `liberarCustodia` (vendedor → comprador, con la comisión a la tesorería), `acreditarDeposito`, `solicitarRetiro`, `decidirRetiro`, `ajustar` (solo admin, con motivo, queda en bitácora).
- Un depósito en curso no se puede acreditar dos veces: hay un guardia contra la carrera (el mismo hash mandado dos veces a la vez) y se vuelve a comprobar después de esperar a la cadena.
- La aritmética es exacta (`lib/decimal.ts`): cadenas decimales a `BigInt` con 18 decimales, comparación, suma, resta, multiplicación y división con recorte hacia abajo. El precio por activo, el monto en moneda local y la cantidad se derivan siempre igual, así que comprador y vendedor ven los mismos números.
- La prueba `flujo.test.ts` termina recorriendo todos los saldos y comprobando que cada uno es exactamente la suma de sus movimientos.

7 · Precio de referencia

Los tres activos están anclados al metal, así que su precio de referencia no sale de un mercado cripto sino del oro y la plata: **1 ORIGEN = 1/55 de gramo de oro**, 1 AUKA = 1 onza troy de oro, 1 AGKA = 1 onza troy de plata. Con el precio del metal en dólares y la tasa dólar → moneda local sale la referencia en cada moneda.

```
ORIGEN en USD = oro_usd_onza × (1/55) / 31,1034768      (gramos por onza troy)
ORIGEN en HNL = ORIGEN en USD × fx[HNL]
anuncio flotante al 103 % → precio = referencia × 1,03
anuncio fijo           → se acepta si está dentro de 10× la referencia
```

- Sobre la referencia trabajan los anuncios **flotantes** (un margen en porcentaje: 97 % compra barato, 103 % vende caro) y contra ella se comparan los **fijos**.
- El precio del metal y las tasas de cambio los fija un **administrador** desde el panel (Precios); al arrancar salen de las variables de entorno (`ORDENEX_ORO_USD_ONZA` , `ORDENEX_PLATA_USD_ONZA`) y de la semilla `fxSemilla.ts` (tasas del 19 de septiembre de 2026; el bolívar con la tasa oficial del BCV). Cambiar el precio mueve todos los anuncios flotantes del mercado, por eso solo lo puede hacer el rol admin.
- Los límites de la plataforma (mínimo por orden, máximo sin ser agente) están en **dólares equivalentes** y se convierten a cada moneda con la misma tasa, así que valen lo mismo en lempiras que en pesos argentinos.
- Los montos en moneda local respetan los decimales de cada moneda (el peso chileno y el guaraní no tienen centavos); un monto con más decimales de los que la moneda admite se rechaza.

Pendiente

Una fuente automática del precio del metal (la misma que usa el resto del ecosistema) y de las tasas, con `fuelle: 'auto'` . El campo ya existe; hoy es manual.

8 · Países, monedas y métodos de pago

`src/data/latam.ts` describe 23 países con su moneda (código, símbolo, decimales), sus bancos principales y los métodos de pago que la gente usa de verdad, cada uno con sus **campos canónicos** (CLABE, llave PIX, número de Nequi, alias de SINPE...) para que el vendedor los rellene bien y el comprador sepa dónde pagar. Se valida contra este catálogo al crear un método de pago o un anuncio.

PAÍS	MONEDA	MÉTODOS DE PAGO
 Argentina	ARS · Peso argentino	Transferencia bancaria, Mercado Pago, Ualá, Brubank, Lemon, Naranja X
 Belice	BZD · Dólar beliceño	Transferencia bancaria, DigiWallet, E-Kyash, Efectivo en persona
 Bolivia	BOB · Boliviano	Transferencia bancaria, Tigo Money, Yape, Efectivo en persona
 Brasil	BRL · Real	PIX, Transferencia bancaria (TED), Efectivo en persona
 Chile	CLP · Peso chileno (sin decimales)	Transferencia bancaria, MACH, Tenpo, Efectivo en persona
 Colombia	COP · Peso colombiano	Nequi, Daviplata, Bre-B (llave), Transferencia bancaria, Movii, Efectivo en persona
 Costa Rica	CRC · Colón	SINPE Móvil, Transferencia bancaria, Efectivo en persona
 Ecuador	USD · Dólar	Transferencia bancaria, Deuna, Efectivo en persona
 El Salvador	USD · Dólar	Transferencia bancaria (Transfer365), Transfer365 Móvil, Tigo Money, Efectivo en persona
 Guatemala	GTQ · Quetzal	Transferencia bancaria, Tigo Money, Efectivo en persona
 Guyana	GYD · Dólar guyanés	Transferencia bancaria, MMG, Efectivo en persona
 Haití	HTG · Gourde	MonCash, NatCash, Transferencia bancaria, Efectivo en persona
 Honduras	HNL · Lempira	Transferencia bancaria, Tigo Money, Efectivo en persona
 México	MXN · Peso mexicano	Transferencia bancaria (SPEI), Mercado Pago, Depósito en OXXO, Efectivo en persona
 Nicaragua	NIO · Córdoba	Transferencia bancaria, Billetera Móvil Banpro, Efectivo en persona
 Panamá	USD · Dólar	Yappy, Transferencia bancaria, Nequi Panamá, Zelle, Efectivo en persona
 Paraguay	PYG · Guaraní (sin decimales)	Transferencia bancaria, Tigo Money, Personal Pay, Zimple, Efectivo en persona
 Perú	PEN · Sol	Yape, Plin, Transferencia bancaria, Efectivo en persona
 Puerto Rico	USD · Dólar	ATH Móvil, Transferencia bancaria, Zelle, Efectivo en persona
 República Dominicana	DOP · Peso dominicano	Transferencia bancaria, Zelle, Efectivo en persona
 Surinam	SRD · Dólar surinamés	Transferencia bancaria, Uni5Pay+, Efectivo en persona
 Uruguay	UYU · Peso uruguayo	Transferencia bancaria, Prex, Mi Dinero, Efectivo en persona
 Venezuela	VES · Bolívar	Pago Móvil, Transferencia bancaria, Zelle, Efectivo en persona

Zelle se liquida en dólares aunque el país tenga otra moneda; el efectivo en persona puede pactarse en dólares. Cada método declara si el pago es instantáneo y qué campos lleva; los datos del vendedor se enseñan solo dentro de una orden abierta y con los números parcialmente enmascarados fuera de ella.

9 · Identidad: KYC contra Genesis ID

OrdenExchange no decide quién es quién. La identidad del ecosistema es **Genesis ID**, y OrdenExchange entra por la misma puerta que Veta Wallet y MyTokenPay: como una app registrada con su clave y sus alcances. Lo que hace OrdenExchange es **acompañar el trámite** desde su propia interfaz y reflejar en la cuenta lo que Genesis ID diga. La aprobación es un acto humano en el panel de Genesis ID; la clave de la app no sirve para aprobar a nadie, y hay una prueba que lo comprueba.

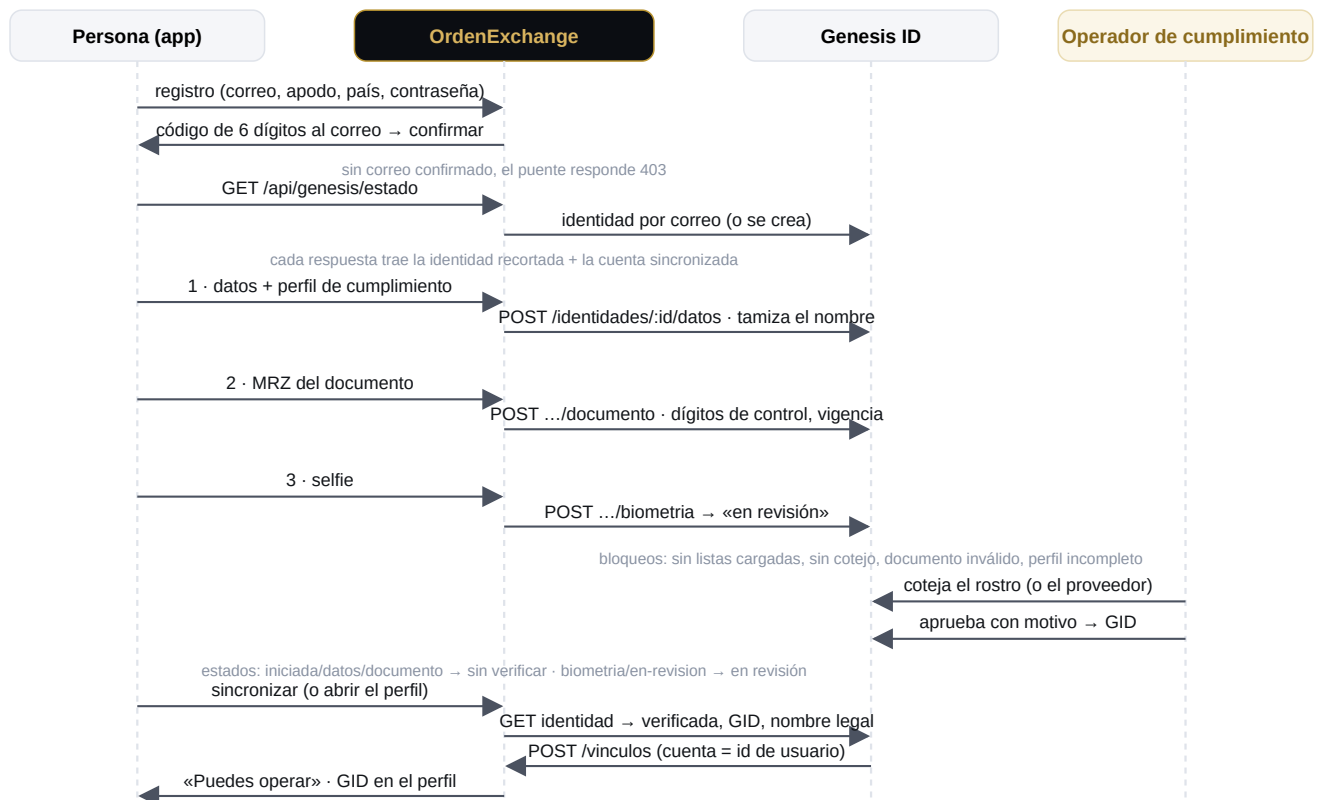


Figura 5 · El trámite completo. La persona nunca habla con Genesis ID; el operador nunca habla con OrdenExchange.

Por qué primero el correo

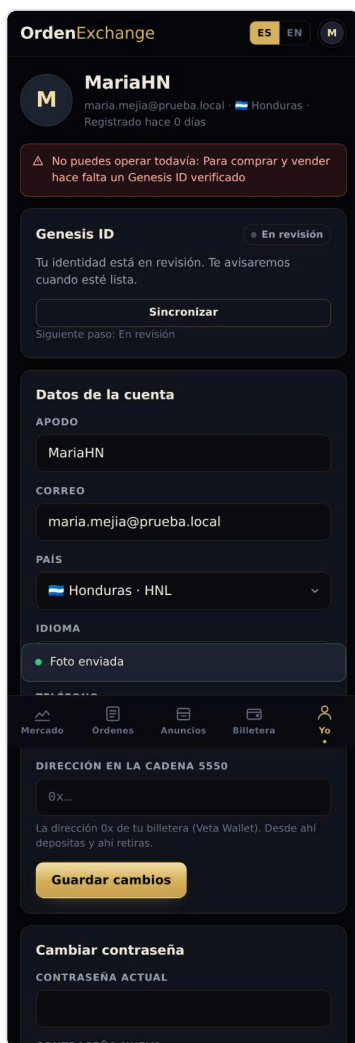
La identidad se busca en Genesis ID **por el correo de la cuenta**. Si el correo no estuviera confirmado, cualquiera que se registrara con el correo de otra persona se quedaría con su identidad y su GID. Por eso el registro manda un código de seis dígitos (Brevo) y todas las rutas del trámite exigen el correo confirmado. Sin proveedor de correo y fuera de producción, el código vuelve en la respuesta para poder probar el flujo entero.

Paso 1 · datos y perfil de cumplimiento:
ocupación, origen de los fondos, volumen
anual, PEP

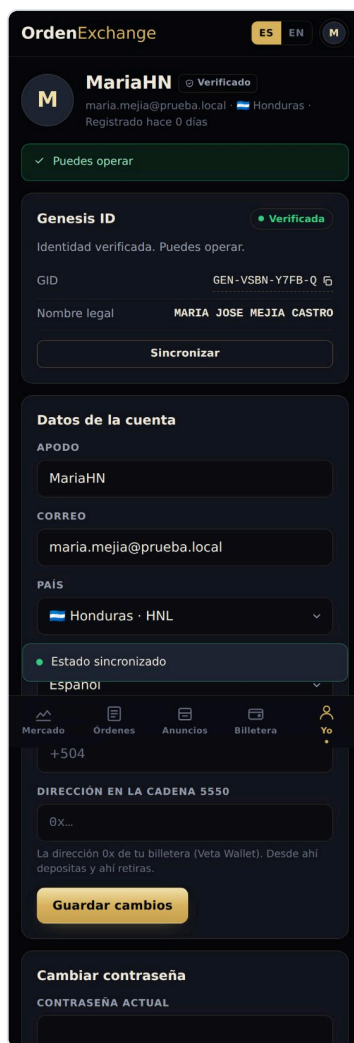
OrdenExchange · Documento de diseño · v1.0

Paso 2 · MRZ del documento; una MRZ alterada se rechaza con el motivo

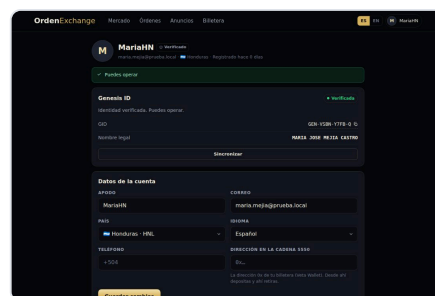
Paso 3 · selfie; con proveedor se coteja solo, sin él lo coteja una persona



En revisión: la cuenta ya lo refleja y el asistente se retira



Tras la aprobación en Genesis ID: GID, nombre legal, «Puedes operar»



Lo mismo en escritorio

Paso 1 • Datos y perfil de cumplimiento. Nombre tal como está en el documento, fecha de nacimiento, país de residencia (ISO3), teléfono, dirección, **ocupación**, **origen de los fondos**, cuánto espera mover al año y si es persona expuesta políticamente. Genesis ID no aprueba a quien declare mover 10 000 USD o más al año (o no declare nada) sin ocupación y origen de fondos: es lo único contra lo que se puede contrastar un movimiento cuando salta una alerta. Al recibir el nombre, Genesis ID lo tamiza contra las listas de sanciones.

Paso 2 • Documento. La MRZ (las dos o tres líneas de caracteres al pie del pasaporte o la cédula) se lee en el teléfono; la imagen del documento no viaja ni se guarda. Genesis ID comprueba los dígitos de control (ICAO 9303), la vigencia y que coincida con lo declarado. Si no es aceptable, la app lo dice y la persona sigue en el paso 2.

Paso 3 • Rostro. Un selfie (comprimido en el teléfono). Con un proveedor de biometría configurado en Genesis ID (Rekognition o un servicio externo) se coteja contra el documento y se hace una prueba de vida por reto; sin proveedor, queda **no-configurada** y lo coteja un operador. En ambos casos la cuenta pasa a **en revisión**. Si el cotejo falla (mala luz, gesto a medias), Genesis ID lo marca como **rostroPendiente** y la app vuelve a enseñar el paso 3 para repetir la foto.

Aprobación. Un operador de cumplimiento, en el panel de Genesis ID, con las listas de sanciones cargadas y sin bloqueos (documento válido, tamizado hecho, rostro cotejado, perfil completo), aprueba con un motivo escrito. Genesis ID emite el GID (GEN-XXXX-XXXX-C , con dígito verificador). Al abrir el perfil o pulsar «Sincronizar», OrdenExchange lo recoge, guarda el nombre legal, **ata la cuenta a la identidad** (vínculo app = ordenexchange, cuenta = id del usuario) y la persona ya puede operar.

Lo que decide Genesis ID manda

ESTADO EN GENESIS ID	ESTADO DE LA CUENTA	QUÉ VE LA PERSONA
iniciada · datos · documento	SIN-VERIFICAR	El asistente, en el paso que toca (paso lo calcula el servidor: 1, 2 o 3)
biometria · en-revision	EN-REVISION	«Tu identidad está en revisión» y el botón Sincronizar; el paso 3 si hay que repetir la foto
verificada	VERIFICADA	GID, nombre legal, insignia «Verificado», «Puedes operar»
rechazada	RECHAZADA	El motivo genérico y el asistente desde el paso 1
suspendida	SUSPENDIDA	«Escribe a soporte». No puede publicar, tomar anuncios ni retirar

- **Nadie opera sin GID verificado:** publicar, tomar un anuncio, depositar y retirar pasan por `usuarios.exigirOperar()`. Un GID de demostración (sufijo `-D`) no vale fuera de la demostración.
- **Una cuenta ya verificada nunca se degrada** porque el correo tenga otra identidad o ninguna (por ejemplo, si entró por sesión única): se avisa y no se cambia nada. Un GID no puede atarse a dos cuentas de `OrdenExchange`.
- **Al usuario se le enseña su trámite, no el expediente:** nunca el tamizado, el riesgo, las notas del operador ni las puntuaciones de parecido. La lista de campos permitidos está en `routes/genesis.ts`.
- **Sesión única.** Con la cuenta verificada, `POST /api/genesis/sso/token` emite un token para entrar en otra app del ecosistema; y `POST /api/auth/sso` acepta el token de otra app: si el GID ya tiene cuenta aquí, entra en ella; si no, completa el registro (correo, apodo, país, contraseña) y queda verificada.
- **Tamizado de direcciones.** Cada retiro tamiza la dirección destino contra las listas de Genesis ID; una dirección sancionada se rechaza, y si Genesis ID no responde el retiro **no sale** (se cierra, no se abre).
- **Monitoreo AML.** Cada orden completada encola un movimiento por cada parte (entrada para el comprador, salida para el vendedor, con monto en USD, país y GID de la contraparte). La cola es persistente (`reportesAml` en el almacén) y se despacha con reintentos crecientes (5 s, 10 s, 20 s... hasta 10 minutos, 12 intentos): un reporte que no llega se reintenta, no se pierde, y `/healthz` enseña cuántos hay pendientes. A la persona nunca se le dice nada de esto.
- **Suspensión.** Si Genesis ID suspende la identidad, la cuenta deja de operar en cuanto se sincroniza (al abrir el perfil, al pulsar Sincronizar o al intentar una acción que lo exija).

Probado contra un Genesis ID de verdad

`npm run prueba:genesis` levanta el Genesis ID del repositorio en un proceso aparte (clave recién emitida, listas de sanciones de prueba, sin proveedor de biometría) y `OrdenExchange` en modo real, y recorre las 28 pruebas: registro → correo → estado → datos → MRZ manipulada rechazada → MRZ válida → selfie → en revisión → la clave de la app no aprueba → el operador no aprueba con bloqueos → cotejo manual y aprobación → GID, nombre legal, vínculo, puede operar → sesión única (mismo usuario, token inventado rechazado) → tamizado de una dirección limpia y una sancionada → un segundo usuario verificado, una compraventa completa y sus dos movimientos en el monitoreo → una suspensión que apaga la cuenta.

Lo que hizo falta arreglar en Genesis ID

Al probar de verdad apareció un defecto en Genesis ID: su limitador de peticiones tenía un solo cubo por IP para todo `/api/v1`, y la primera ruta que se tocaba fijaba la capacidad de todas (mandar un rostro, 20 por minuto, dejaba sin fichas al monitoreo AML). Como todas las apps del ecosistema hablan con Genesis ID desde una sola IP de servidor, eso habría estrangulado el monitoreo en producción. Ahora el cubo es por ruta (`genesis-id/src/middleware/proteger.ts`); las 151 pruebas de Genesis ID siguen pasando.

10 · Agentes de cambio

Un agente de cambio es el equivalente del «comerciante verificado» de Binance P2P: alguien que opera con volumen, responde rápido y ha dejado una **garantía** en ORIGEN que responde por su conducta. Lleva insignia en el mercado, puede superar el máximo por orden de los usuarios normales y puede publicar anuncios «solo para agentes».

REQUISITO	VALOR POR DEFECTO	DÓNDE SE CAMBIA
Genesis ID verificado	obligatorio	—
Garantía en ORIGEN, congelada mientras sea agente	500 ORIGEN	Panel → Configuración (<code>garantiaAgente</code>)
Órdenes completadas mínimas	0	<code>ORDENEX_AGENTE_ORDENES_MIN</code>
Máximo por orden sin ser agente	5 000 USD equivalentes	Configuración (<code>maxOrdenUsdSinAgente</code>)

- **Solicitar** congela la garantía en el acto (movimiento `garantia-agente`). Un operador con permiso `agentes.decidir` aprueba o rechaza desde el panel; al rechazar, la garantía vuelve.
- **Suspender** a un agente le quita la insignia y los privilegios pero no le devuelve la garantía; un agente suspendido no puede renunciar ni volver a solicitar hasta que un operador lo decida.
- **Renunciar** devuelve la garantía (`garantia-devuelta`) si no tiene órdenes abiertas.
- La pantalla «Agente de cambio» enseña los requisitos con lo que falta, la garantía y el estado de la solicitud; el panel lista las solicitudes pendientes y los agentes activos.

OrdenExchange DEMO Mercado Órdenes 1 Anuncios Billetera ES EN C Comprador1

Agente de cambio

¿Qué es un agente de cambio?

Un comerciante verificado con insignia en el mercado. Deja una garantía en ORIGEN en custodia, lo aprueba un operador y puede abrir órdenes por montos mayores. La insignia dice a los demás que hay una garantía detrás.

Requisitos

Todavía no cumples los requisitos

✓ Genesis ID verificado

✗ Tener 500.00 ORIGEN disponibles para la garantía

✓ 0 de 0 órdenes completadas

Garantía 500.00 ORIGEN

Queda en custodia mientras seas agente. Se devuelve al renunciar o si la solicitud se rechaza o se retira.

Solicitar ser agente

CUÉNTANOS DE TI

Cómo operas, horarios, bancos con los que trabajas, experiencia...

La pantalla del agente: requisitos, garantía y solicitud

11 · Billetera, depósitos y retiros

No hay llaves privadas en OrdenExchange. La cuenta de la plataforma en la cadena 5550 es la **tesorería** (`ORDENEX_TESORERIA`): a ella deposita la gente y desde ella firma los retiros un operador, fuera del servidor.

Depositar

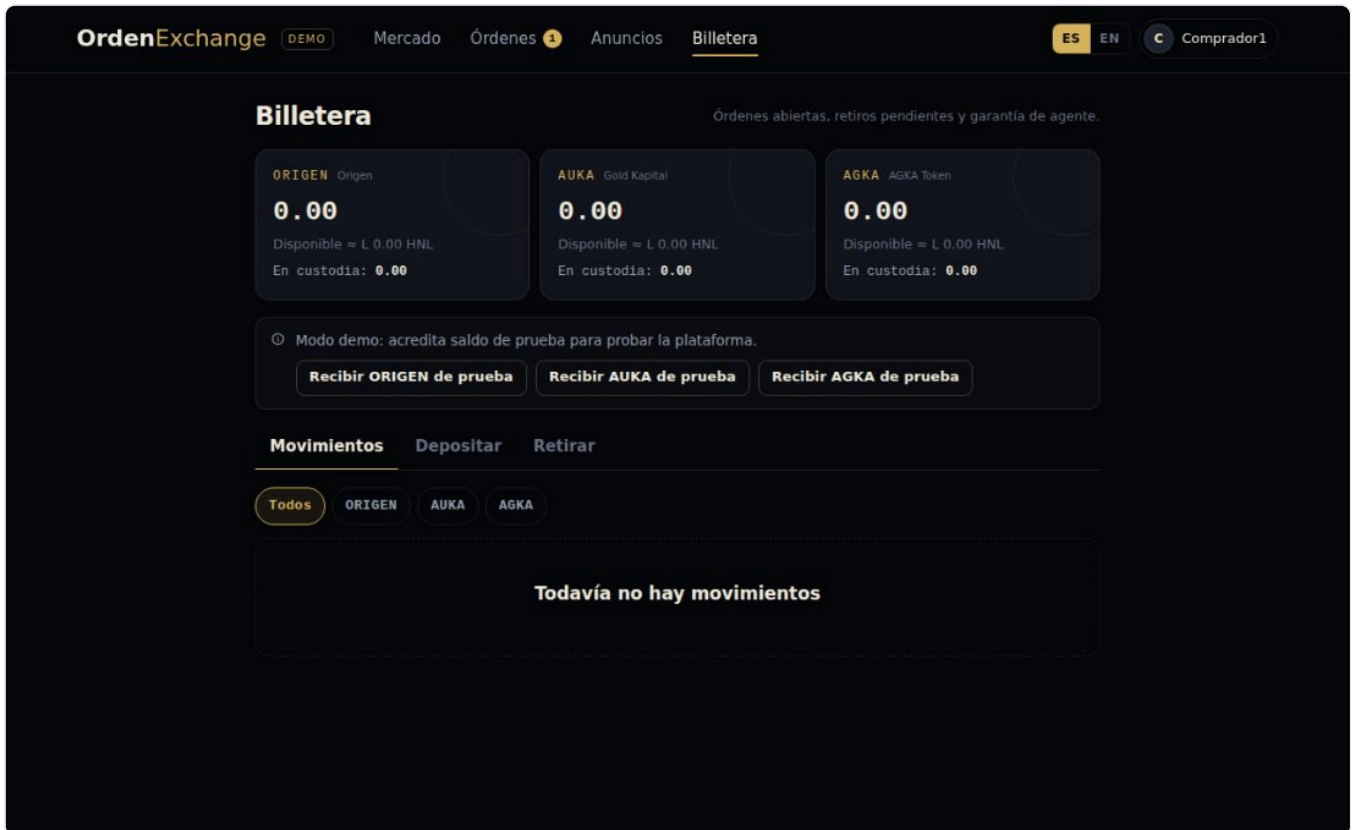
- 1 La persona registra en su perfil la dirección 0x de su billetera (Veta Wallet). Cambiarla guarda la anterior en el historial: una dirección no puede pertenecer a dos cuentas.
- 2 Transfiere desde esa dirección a la tesorería (ORIGEN nativo, o AUKA/AGKA por el contrato ERC-20) y pega el hash de la transacción en la billetera.
- 3 El servidor comprueba por JSON-RPC: que la transacción existe y tuvo éxito, que el destino es la tesorería, que el origen es la dirección registrada, que tiene las confirmaciones exigidas (3 por defecto) y, para AUKA y AGKA, que el evento `Transfer` del contrato correcto dice esa cantidad. El hash es único: no se acredita dos veces.
- 4 Se acredita al saldo disponible (movimiento `deposito` con el hash como referencia) y queda en el panel → Depósitos.

Retirar

- 1 La persona pide un retiro (activo, cantidad, dirección destino, contraseña). La dirección se **tamiza** en Genesis ID; sancionada, se rechaza; sin respuesta, no sale.
- 2 La cantidad pasa a congelado (`retiro-solicitado`). Mientras esté pendiente, la persona puede cancelarlo y vuelve a disponible.
- 3 Un operador con `retiros.decidir` firma la transferencia desde la tesorería, fuera del servidor, y anota el hash en el panel: `retiro-enviado` descuenta de congelado. O lo rechaza con motivo: vuelve a disponible.

Pendiente

Firmar los retiros desde un servicio con la llave de la tesorería (o una multifirma) en lugar de a mano. El contrato de la ruta ya está: la decisión del operador con el hash.



La billetera: saldo disponible y en custodia por activo, depósito por hash, retiros e historial

12 · Las pantallas de la app

La app es una sola página (`public/index.html` + `app.js`) con enrutado por `#/ruta` , en español e inglés, pensada primero para el teléfono. Negro profundo con oro como acento, verde para comprar y rojo-coral para vender, como en cualquier mercado. Las pantallas y lo que hay en cada una:

ruta	Pantalla	Qué hay
<code>#/</code> · <code>#/mercado</code>	Mercado	Pestañas comprar/vender, activo, país (con su moneda), método de pago, monto, solo agentes; lista de anuncios con precio, disponible, límites, métodos, reputación e insignias; precio de referencia.
<code>#/anuncio/:id</code>	Tomar un anuncio	Términos, requisitos, monto en moneda local o cantidad, método, resumen y confirmación.
<code>#/orden/:id</code>	Orden	Estado y temporizador, resumen, datos de pago del vendedor (solo aquí), chat con imágenes, botones según el estado (pagado, liberar, cancelar, apelar, calificar).
<code>#/ordenes</code>	Mis órdenes	Abiertas e historial, con filtros.
<code>#/anuncios</code> · <code>#/anuncios/nuevo</code>	Mis anuncios	Lista con pausar/reanudar/cerrar, editor completo con vista previa del precio.
<code>#/billetera</code>	Billetera	SalDOS, depositar (hash), retirar, historial de movimientos, depósitos y retiros.
<code>#/pagos</code>	Métodos de pago	Alta por catálogo del país con sus campos, activar/desactivar.
<code>#/agente</code>	Agente de cambio	Requisitos, garantía, solicitud, renuncia.
<code>#/perfil</code>	Perfil	Confirmación del correo, Genesis ID (estado, asistente, GID, nombre legal), datos de la cuenta, contraseña, reputación, salir.
<code>#/entrar</code> · <code>#/registro</code>	Entrar y registro	Correo y contraseña, registro con país; en demostración, entrar con un clic como cualquiera de los diez usuarios.

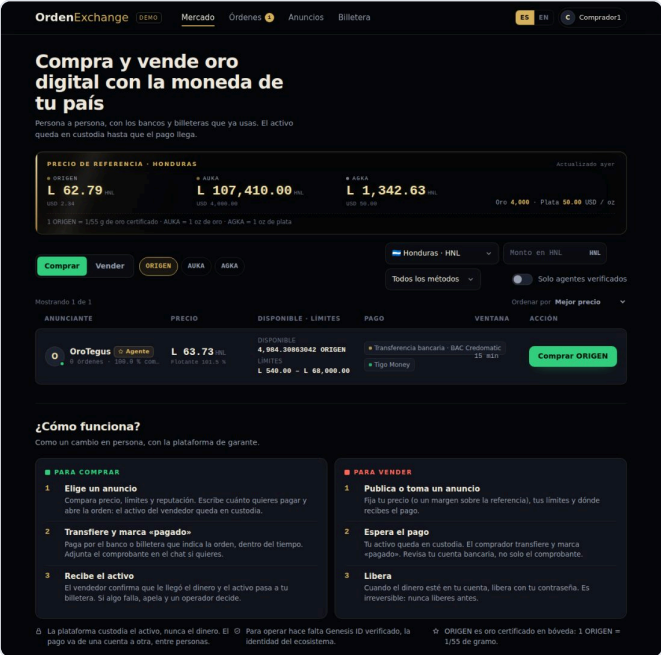
Identidad visual y movimiento

Negro profundo, oro como acento (nunca como fondo grande), verde para comprar y coral para vender; tipografía sans para leer y monoespaciada para todo número, con cifras tabulares para que las columnas cuadren. El movimiento está gastado en **una sola idea**: el activo entra en custodia y sale de ella. Todo lo demás es el acabado que se espera de un mercado, sin nada que distraiga de los números.

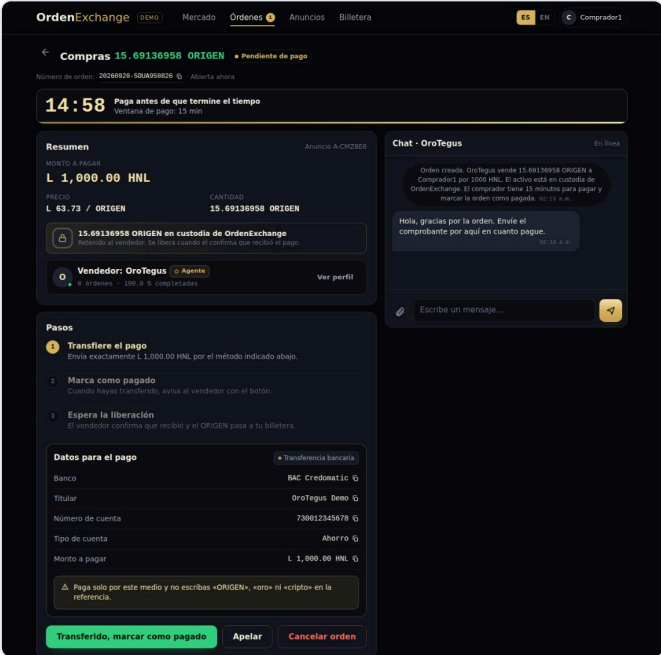
DÓNDE	QUÉ SE MUEVE	POR QUÉ
La banda de custodia, en cada orden	El candado cae y late mientras el activo está retenido; al liberar, el trazo del visto se dibuja en verde; al cancelar, la flecha de vuelta en gris.	Es el elemento firma: dice en una frase dónde está el activo ahora mismo, que es lo único que de verdad importa en una orden.
El temporizador	Una barra dorada que se consume bajo el reloj; a tres minutos se vuelve coral y el reloj late.	El tiempo que queda se ve sin leer los dígitos.
La pizarra de precios	Un destello de bóveda recorre el tablero cada ocho segundos; los precios se encienden al llegar; los puntos de cada activo respiran.	El tablero está vivo: los precios son de ahora.

DÓNDE	QUÉ SE MUEVE	POR QUÉ
Cambiar de pantalla	La vista entra con un deslizamiento corto y las listas (anuncios, órdenes, tarjetas) aparecen escalonadas. Las repintadas del sondeo no vuelven a animar.	Orientación: se nota que la pantalla cambió, sin esperar.
Estados	El punto de «pendiente de pago», «en revisión» y «apelación» parpadea despacio.	Alguien tiene que hacer algo.
Botones, filas, campos	Se levantan al pasar, se hunden al pulsar; el botón dorado brilla; el anuncio se acerca y su precio se enciende; el campo enfocado tiene un halo dorado; el subrayado de la navegación y el punto de la barra crecen desde el centro.	Respuesta inmediata a cada gesto; foco visible con teclado.
Chat, avisos y diálogos	Los mensajes suben al aparecer; los avisos y diálogos emergen con una escala mínima.	Continuidad.

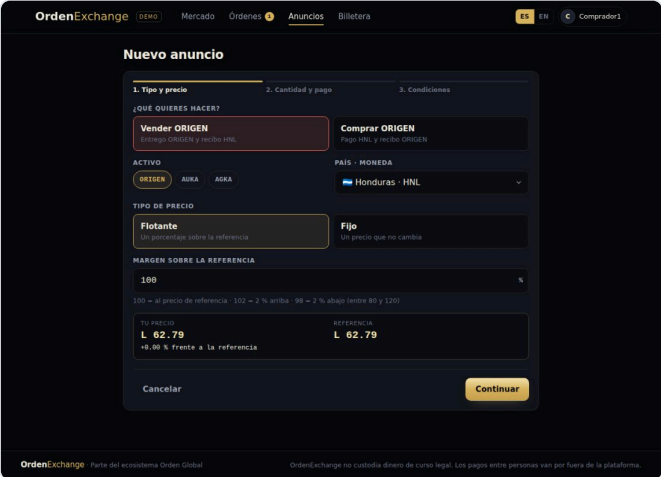
Con «reducir movimiento» activado en el sistema, todas las animaciones y transiciones se apagan (prefers-reduced-motion). En el teléfono la pizarra enseña cada precio en su renglón, como un tablero de cotizaciones, para que ningún número se corte.



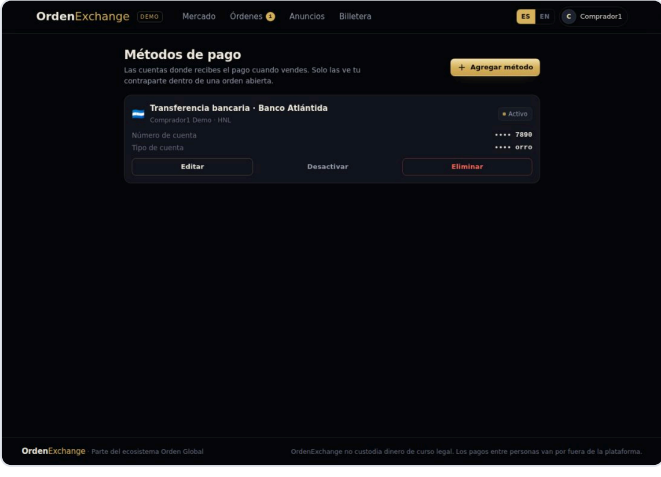
El mercado en escritorio



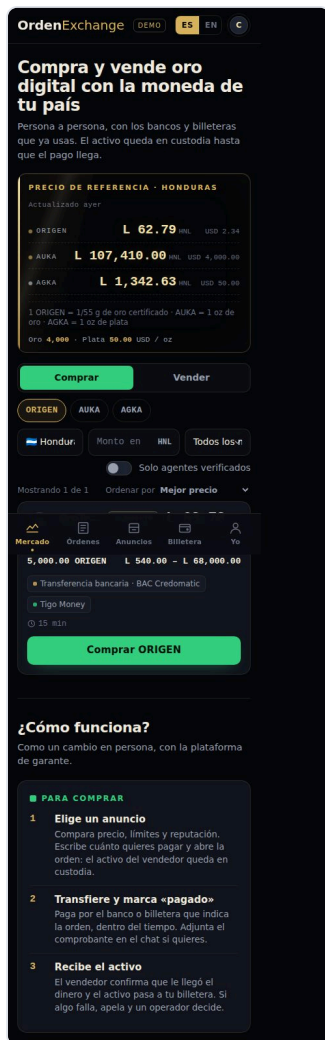
Una orden abierta



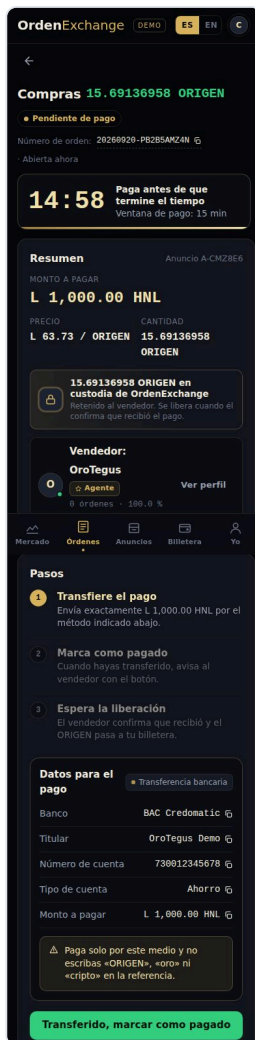
Publicar un anuncio



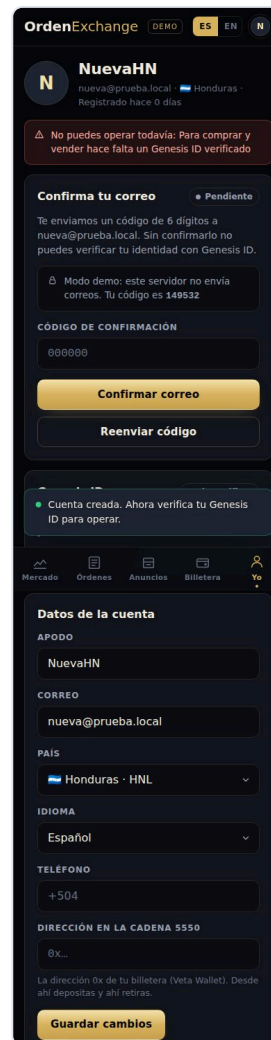
Métodos de pago por catálogo del país



Mercado en el teléfono



Orden en el teléfono



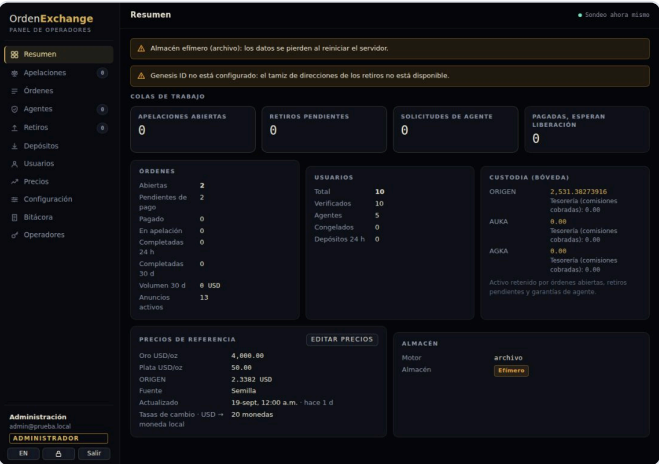
Registro: confirmar el correo

13 · Panel de operadores

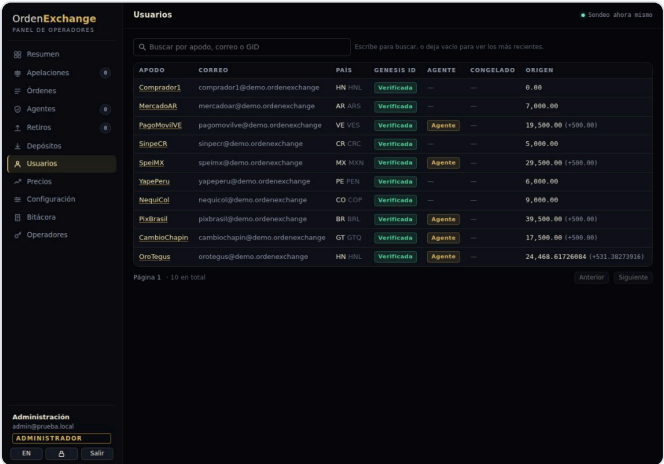
En `/admin` , con sesión propia de operador (no la de usuario). Tres roles, y cada acción del panel exige un permiso concreto:

PERMISO	ADMIN	SOPORTE	AUDITOR	QUÉ PERMITE
<code>leer</code>	✓	✓	✓	Ver todo: resumen, órdenes, usuarios, retiros, depósitos, agentes, precios, configuración, bitácora
<code>ordenes.resolver</code> · <code>ordenes.cancelar</code> · <code>ordenes.chatear</code>	✓	✓	—	Resolver apelaciones (liberar / devolver), cancelar órdenes, escribir en el chat de una apelación
<code>agentes.decidir</code> · <code>retiros.decidir</code>	✓	✓	—	Aprobar, rechazar o suspender agentes; marcar retiros enviados (con hash) o rechazados
<code>usuarios.congelar</code>	✓	✓	—	Bloquear una cuenta (cierra todas sus sesiones) y desbloquearla
<code>salDOS.ajustar</code>	✓	—	—	Ajuste manual de saldo con motivo (queda en bitácora)
<code>precios.editar</code> · <code>configuracion.editar</code>	✓	—	—	Precio del metal y tasas; comisión, garantía, límites, tesorería
<code>operadores.gestionar</code>	✓	—	—	Crear y desactivar operadores, cambiar roles

- La **bitácora** es una cadena de hashes: cada entrada lleva el hash de la anterior y el panel comprueba que está íntegra. Toda decisión de operador queda ahí con su nombre.
- Las **apelaciones** se resuelven con el chat completo y los comprobantes a la vista; la resolución escribe un mensaje del sistema en la orden.
- El primer administrador sale de `ORDENEX_ADMIN_EMAIL` ; si no se fija `ORDENEX_ADMIN_PASSWORD` , se genera y se imprime una sola vez al arrancar. Bloqueo por correo + IP tras intentos fallidos; el token de sesión se guarda por hash.



Resumen



Usuarios: congelar, ajustar, ver

OrdenExchange

PANEL DE OPERADORES

Resumen

Apelaciones

Órdenes

Agentes

Retiros

Depósitos

Usuarios

Precios

Configuración

Bitácora

Operadores

Administración

Administradores

EN

Salir

Precios

● hoy ahora mismo

METALLES - USD POR ONZA TROY

oro USD/OZ

plata USD/OZ

4000

50

Simula - hasta 1 d

REFERENCIA RESULTANTE

ORIGEN

USD

AUKA

USD

AGKA

USD

2.3382

4,000.00

50.00

1 ORIGEN = 1.05 g de oro - 1 AUKA = 1 oz de oro - 1 AGKA = 1 oz de plata

Los precios de precios Bitácora se calculan sobre estas referencias.

TASAS DE CAMBIO - USD - MONEDA LOCAL

MONEDA	NOMBRE	PAIS	TASA	ORIGEN	AUKA	AGKA
ARS	Peso argentino	AR	1512.33	3,536.1846	6,645,320.00	75,610.50
BOB	Boliviano	BO	10.87	25.4166	43,480.00	543.50
BRL	Real brasileño	BR	5.1303	12.0009	20,545.20	236.82
BZD	Dólar beliceño	BZ	2	4.6705	8,000.00	100.00
CLP	Peso chileno	CL	959.04	2,243.8649	3,838,500.00	47,982.00
COP	Peso colombiano	CO	3127.04	7,313.1608	12,510,500.00	156,302.00
CRC	Colón costarricense	CR	448.11	1,947.787	3,782,440.00	22,400.50
DOP	Peso dominicano	DO	58.88	137.6753	238,520.00	2,044.00
GTQ	Quetzal	GT	7.6376	17.0585	30,550.40	381.88
GYP	Dólar guyanés	GY	209.29	489.3604	837,100.00	10,454.50
HNL	Lempira	HN	26.0525	62.7875	107,410.00	1,342.63
HTG	Gourde	HT	139.72	305.0542	522,800.00	6,530.00
MXN	Peso mexicano	MX	17.2121	40.240	68,640.00	800.81
NIO	Córdoba	NI	36.778	85.9956	147,112.00	1,838.00
PER	Sol	PE	3.3645	7.807	13,450.00	168.23
PYG	Guaraní	PY	5035.09	13,078.8109	23,742,300.00	296,779.50
SRD	Dólar surinamés	SR	37.848	88.4976	151,392.00	1,692.40

Precios del metal y tasas

OrdenExchange

PANEL DE OPERADORES

Resumen

Apelaciones

Órdenes

Agentes

Retiros

Depósitos

Usuarios

Bitácora

Configuración

Operadores

Administración

Administradores

EN

Salir

Bitácora

● hoy ahora mismo

Q. Buscar por actor, acción u objeto

Cadena de hashes integrada

N.º	CUANDO	ACTOR	ACCION	OBJETO	DETALLE	HASH
40	20-sept-02-12 a.m.	admin@proba.local	panel.entrado	opr_mu6y11vbn51rhu	()	7 500765.496
40	20-sept-02-12 a.m.	usr_mu96291d05mk569g	orden.creada	ord_mu6eqj20012aybu	Ver detalle	7 500762.401
47	20-sept-02-12 a.m.	usr_mu96291d05mk569g	orden.creada	ord_mu6mca71ic2y3yan	Ver detalle	7 730408.470
40	20-sept-02-12 a.m.	sistema	demo.sembrada	demo	Ver detalle	7 730208.470
45	20-sept-02-12 a.m.	usr_mu96261d4ndevt04	anuncio.creado	anu_mu61b956fncgpyr	Ver detalle	7 830204.701
44	20-sept-02-12 a.m.	usr_mu9624b8e3uqkmrs	anuncio.creado	anu_mu61b97794feh33rc	Ver detalle	7 790009.307
43	20-sept-02-12 a.m.	usr_mu9624b8e3uqkmrs	anuncio.creado	anu_mu61b979eah31uq4	Ver detalle	7 790008.302
42	20-sept-02-12 a.m.	usr_mu962261322j7gt	anuncio.creado	anu_mu61b9fdayarbp4s	Ver detalle	7 780078.300
41	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9fdayarbp4s	Ver detalle	7 730208.470
40	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
39	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
38	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
37	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
36	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
35	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
34	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
33	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
32	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
31	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
30	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
29	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
28	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
27	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
26	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300
25	20-sept-02-12 a.m.	usr_mu96291d05mk569g	anuncio.creado	anu_mu61b9eq4730b0e4	Ver detalle	7 707400.300

Bitácora encadenada

14 · Seguridad

Lo que protege el dinero y los datos, tal como está en el código. Cada punto salió de una revisión adversarial sobre la aplicación y tiene su prueba.

RIESGO	CÓMO SE CUBRE
Sesiones falsificadas	JWT firmado con <code>ORDENEX_JWT_SECRETO</code> , obligatorio en producción (sin él el servidor no arranca). El usuario se toma siempre de la sesión, nunca del cuerpo de la petición.
Sesiones que no se pueden cerrar	Cada usuario lleva <code>sesionesDesde</code> ; cualquier token emitido antes deja de valer. Cerrar sesión, cambiar la contraseña o que un operador congele la cuenta mueven la marca. El instante de emisión va en milisegundos para poder revocar y emitir en el mismo segundo.
Adivinar contraseñas o correos	bcrypt; la comparación tarda lo mismo aunque la cuenta no exista (hash ficticio); ocho intentos fallidos bloquean 15 minutos; límites de peticiones por ruta e IP.
Quedarse con la identidad de otro	El correo se confirma con código antes de abrir el trámite en Genesis ID; un GID no se ata a dos cuentas; una cuenta verificada no se degrada por otra identidad.
Liberar lo ajeno · cancelar lo pagado · tomar el propio anuncio	Cada acción comprueba el papel de quien la pide y el estado de la orden; liberar exige la contraseña. Probado negativamente en <code>flujo.test.ts</code> .
Saldos inventados o negativos	Un solo punto de mutación, BigInt, rechazo entero, movimientos que suman el saldo (sección 6). Guardia contra la carrera de depósitos; hash de depósito y de retiro únicos.
Demostración encendida sobre dinero real	Una sola definición de producción; el grifo y la verificación falsa no existen en producción; las cuentas de demostración se congelan; el GID de demostración no vale.
Datos bancarios y comprobantes expuestos	Los métodos de pago se ven solo dentro de una orden abierta (enmascarados fuera); las imágenes del chat se sirven con URL firmada por HMAC y solo a las partes y al operador.
Inyección y scripts en el navegador	Content-Security-Policy estricta (sin scripts externos), HSTS, CORS solo a los orígenes configurados en producción, todo el HTML del frontend escapado.
Retiros a direcciones sancionadas	Tamizado en Genesis ID antes de aceptar el retiro, que se cierra si Genesis ID no responde.
Decisiones sin rastro	Bitácora encadenada con el operador, la acción y el detalle; el panel verifica la integridad.
Detrás de un proxy	<code>trust proxy</code> solo cuando se sabe que hay uno (Render, Vercel o <code>ORDENEX_TRAS_PROXY=1</code>), para que los límites por IP no se puedan burlar con una cabecera.

15 · La API, en resumen

El contrato completo, con cada campo y cada código de error, está en `ordenexchange/API.md` . Todo devuelve JSON; los errores llevan `{ error, codigo }` y el frontend traduce el código. Sesión de usuario con `Authorization: Bearer` ; sesión de operador aparte para `/api/panel` .

GRUPO	RUTAS
Público	<code>GET /api/mercado/catalogo</code> (países, monedas, métodos, activos, precios, configuración visible, demo) · <code>GET /api/mercado/anuncios</code> (filtros: lado, activo, pais, moneda, metodo, monto, soloAgentes, orden) · <code>GET /api/mercado/anuncios/:id</code> · <code>GET /api/mercado/usuarios/:id</code> · <code>GET /healthz</code>
Autenticación	<code>POST /api/auth/registro</code> · <code>verificar-correo</code> · <code>reenviar-codigo</code> · <code>entrar</code> · <code>sso</code> · <code>salir</code> · <code>GET/PATCH /api/auth/yo</code> · <code>POST /api/auth/contrasena</code> · <code>demo: demo/usuarios</code> , <code>demo/entrar</code>
Genesis ID	<code>GET /api/genesis/estado</code> · <code>POST datos</code> · <code>documento</code> · <code>vivacidad</code> · <code>biometria</code> · <code>foto</code> · <code>vincular</code> · <code>sso/token</code> · <code>GET tamiz/:direccion</code> · <code>demo: demo/verificar</code>
Billetera	<code>GET /api/billetera</code> · <code>movimientos</code> · <code>POST depositos (hash)</code> · <code>GET depositos</code> · <code>POST retiros</code> · <code>GET retiros</code> · <code>POST retiros/:id/cancelar</code> · <code>demo: grifo</code>
Métodos de pago	<code>GET/POST /api/metodos-pago</code> · <code>PATCH/DELETE /:id</code>
Mis anuncios	<code>GET/POST /api/anuncios</code> · <code>GET/PATCH /:id</code> · <code>POST /:id/pausar</code> · <code>reanudar</code> · <code>cerrar</code>
Órdenes	<code>GET/POST /api/ordenes</code> · <code>GET /:id</code> · <code>POST /:id/pagado</code> · <code>liberar</code> · <code>cancelar</code> · <code>apelar</code> · <code>retirar-apelacion</code> · <code>calificar</code> · <code>GET/POST /:id/mensajes</code> · <code>GET /:id/imagenes/:img?f=</code>
Agentes	<code>GET /api/agentes/estado</code> · <code>POST solicitar</code> · <code>renunciar</code>
Panel	<code>POST /api/panel/sesion/entrar</code> · <code>GET resumen</code> · <code>apelaciones</code> · <code>ordenes</code> · <code>POST ordenes/:id/resolver</code> · <code>cancelar</code> · <code>mensaje</code> · <code>GET usuarios</code> · <code>usuarios/:id</code> · <code>POST usuarios/:id/congelar</code> · <code>ajuste</code> · <code>agente</code> · <code>GET agentes</code> · <code>retiros</code> · <code>POST retiros/:id/decidir</code> · <code>GET depositos</code> · <code>GET/PUT precios</code> · <code>configuracion</code> · <code>GET bitacora</code> · <code>GET/POST operadores</code> · <code>POST contrasena</code>

Tiempo real: la app sondea la orden abierta cada pocos segundos (`GET /api/ordenes/:id/mensajes` devuelve el detalle ligero con los mensajes nuevos). No hay WebSockets; con el volumen previsto no hacen falta.

16 · Despliegue y configuración

Un solo proceso Node 22. En **Render**, el servicio `ordenexchange` está en el `render.yaml` de la raíz del monorepo (`rootDir ordenexchange`, `npm install`, `npm start`, comprobación en `/healthz`). En **Vercel**, `vercel.json` apunta a `src/index.ts`; ahí Mongo es obligatorio porque el disco es efímero. `GET /healthz` responde `degradado` mientras falte algo esencial y dice qué.

VARIABLE	PARA QUÉ	OBLIGATORIA EN PRODUCCIÓN
ORDENEX_JWT_SECRETO	Firma de las sesiones de usuario	Sí (sin ella no arranca)
ORDENEX_MONGO_URL · ORDENEX_MONGO_DB	Almacén persistente (sin ella, JSON en disco)	Sí para custodiar saldos reales
ORDENEX_ADMIN_EMAIL · ORDENEX_ADMIN_PASSWORD	Primer administrador del panel	Recomendada (si no, se genera e imprime)
GENESIS_URL · GENESIS_API_KEY	El puente con Genesis ID (clave de la app <code>ordenexchange</code>)	Sí: sin ella nadie se verifica ni opera
BREVO_API_KEY · ORDENEX_CORREO_REMITENTE	Código de confirmación del correo	Sí: sin proveedor nadie confirma su correo en producción
ORDENEX_TESORERIA · ORDENEX_RPC_URL · ORDENEX_CONFIRMACIONES · ORDENEX_EXPLORADOR	Cadena 5550: cuenta de la plataforma, nodo, confirmaciones, explorador	Sí para depósitos y retiros
ORDENEX_ORO_USD_ONZA · ORDENEX_PLATA_USD_ONZA	Precio inicial del metal (luego desde el panel)	Sí
ORDENEX_COMISION_PCT · ORDENEX_GARANTIA_AGENTE · ORDENEX_MAX_ORDENES_ABIERTAS · ORDENEX_MIN_ORDEN_USD · ORDENEX_MAX_ORDEN_USD_SIN_AGENTE · ORDENEX_AGENTE_ORDENES_MIN	Reglas de la plataforma (todas editables después desde el panel)	Opcionales (0 %, 500, 5, 5, 5 000, 0)
ORDENEX_ORIGENES · ORDENEX_TRAS_PROXY	CORS y proxy inverso	Según despliegue
ORDENEX_DEMO	Forzar la demostración (1/0). Nunca actúa en producción	No

```
cd ordenexchange
npm install
npm start           # http://localhost:4100 → app en /, panel en /admin
npm run prueba      # 47 pruebas en modo demostración
npm run prueba:genesis # 28 pruebas contra el Genesis ID del repositorio
npm run typecheck
```

17 • Pruebas

Las pruebas son de extremo a extremo sobre el servidor de verdad (`node:test` , sin dobles): arrancan el servidor en un puerto libre, hacen peticiones HTTP y comprueban respuestas y estado. Además se recorrió la interfaz con Chromium (Playwright) en teléfono y escritorio para las capturas de este documento y para comprobar que cada pantalla y cada flujo funcionan en el navegador.

SUITE	PRUEBAS	QUÉ CUBRE
<code>decimal.test.ts</code>	incluidas en las 47	La aritmética exacta: conversión, comparación, suma, resta, multiplicación, división con recorte, validación de decimales.
<code>flujo.test.ts</code> (demostración)	47 en total	Catálogo y mercado; registro y confirmación del correo; verificación; orden de compra con custodia, chat, marcar pagado, liberar con contraseña, calificar; orden de venta sobre un anuncio de compra; cancelación y vencimiento; apelaciones resueltas en los dos sentidos; permisos de auditor; congelar cuentas (cierra sesiones); precios; anuncios propios con requisitos; retiros; agentes; y al final, que cada saldo cuadra con sus movimientos. También todo lo que NO se puede hacer: liberar lo ajeno, cancelar lo pagado, tomar el propio anuncio, operar sin GID, mover más de lo que hay en custodia.
<code>genesis.integracion.ts</code> (Genesis ID real)	28	Sección 9: el trámite entero contra el Genesis ID del repositorio, sesión única, tamizado, monitoreo AML y suspensión.
Genesis ID (<code>genesis-id/</code>)	151	Siguen pasando tras el arreglo del limitador.

Total: **75 pruebas** de OrdenExchange, todas en verde en la fecha de este documento, más las 151 de Genesis ID.
`npm run typecheck` compila sin errores.

18 · Lo que falta y lo que sigue

Para salir a producción

QUÉ	POR QUÉ	DÓNDE
MongoDB	El archivo JSON sirve para desarrollo; con saldos reales hace falta un almacén persistente y con respaldo.	ORDENEX_MONGO_URL ; el código ya lo soporta.
Clave real de la app en Genesis ID	La app <code>ordenexchange</code> ya está registrada; hay que fijar su clave <code>gid_live_...</code> en el servidor.	GENESIS_API_KEY
Proveedor de correo	Sin Brevo nadie puede confirmar su correo y, por tanto, verificarse.	BREVO_API_KEY
Tesorería y firma de retiros	Cuenta de la plataforma en la cadena 5550 y quién firma; hoy los retiros se firman a mano y se anota el hash.	ORDENEX_TESORERIA ; después, un firmante o multifirma.
Proveedor de biometría en Genesis ID	Sin él, cada rostro lo coteja una persona. Con Rekognition o un servicio externo el cotejo y la prueba de vida son automáticos.	GENESIS_AWS_ACCESS_KEY_ID o GENESIS_BIOMETRIA_URL en Genesis ID
Listas de sanciones en Genesis ID	Genesis ID no aprueba a nadie sin listas cargadas.	GENESIS_LISTAS_DIR o importación OFAC desde su panel
Precio del metal automático	Hoy lo fija un administrador.	Una fuente periódica con <code>fuelle: 'auto'</code>

Mejoras razonables después

- **Lectura de la MRZ con la cámara** (OCR en el teléfono) en lugar de teclearla; el contrato ya recibe solo el texto.
- **Prueba de vida por reto** en la app (la ruta `/vivacidad` ya existe y el puente reenvía `reto` y `fotogramas`).
- **Notificaciones** (correo o push) al comprador y al vendedor en cada cambio de estado; hoy el aviso es dentro de la app.
- **Contrapartes bloqueadas** y lista de favoritos, como en Binance.
- **Estadísticas del mercado** (volumen por país y moneda) en el panel y en el cerebro del ecosistema.
- **Aplicación móvil** envolviendo la SPA, que ya está pensada para el teléfono.

19 · Glosario

Anuncio	Oferta pública de compra o venta con precio, límites y métodos de pago. Lo publica el anunciante; lo toma el tomador.
Orden	Una compraventa concreta sobre un anuncio, con su custodia, su chat y su temporizador.
Custodia (congelado)	El activo del vendedor retenido por la plataforma mientras dura la orden. «Congelar» y «descongelar» en la interfaz.
Liberar	El vendedor entrega el activo en custodia al comprador tras comprobar que cobró.
Apelación	Disputa sobre una orden pagada que resuelve un operador: liberar o devolver.
Agente de cambio	Comerciante verificado con garantía e insignia; puede operar montos mayores.
Genesis ID · GID	La identidad del ecosistema y su identificador (GEN-XXXX-XXXX-C).
MRZ	Zona de lectura mecánica: las líneas de caracteres al pie de un pasaporte o cédula (ICAO 9303).
KYC · AML · PEP	Conocer al cliente; prevención de lavado de activos; persona expuesta políticamente.
Tamizado	Comparar un nombre o una dirección contra listas de sanciones.
Tesorería	La cuenta de la plataforma en la cadena 5550: recibe los depósitos y desde ella salen los retiros y se cobran las comisiones.
Precio de referencia	El valor del activo en cada moneda derivado del metal (oro o plata) y de la tasa de cambio.
Flotante	Precio expresado como porcentaje sobre la referencia; se mueve con ella.
Bitácora	Registro encadenado por hashes de toda decisión y cambio relevante.

OrdenExchange · Documento de diseño · versión 1.0 · 20 de septiembre de 2026 · generado desde <ordenexchange/docs/disenio.html> con Chromium. Las capturas provienen de recorridos reales con Playwright sobre el servidor en modo demostración y, para la identidad, sobre un Genesis ID real levantado desde el repositorio.